ITA1435 - Ethical Hacking

Assignment 2

Evaluation and Engineering of Footprinting, Reconnaissance and Social-Engineering-Awareness Workflows in an Authorized Assessment

NAME: T.ARUN KUMAR

Reg no:192372325

Dept: CSE(AI)

Scope and authorization statement: all work uses lab-owned targets and reserved .example / .lab.example domains (RFC 2606). No attack is launched against live systems or real people, and the social-engineering part is awareness analysis only.

How the evidence was produced: the 'observed' values come from the accompanying script recon_sim.py (synthetic lab data, fixed random seed 42, no network traffic), so every table can be reproduced by running it. Commands such as whois, dig and nslookup are given for each workflow; for your submission, run them in your own authorized lab and attach the raw output as an annex.

Assessment flow followed: Understand -> Predict -> Design -> Collect -> Analyse -> Evaluate -> Defend -> Validate.

Q1 - Evaluate and Engineer a Footprinting Strategy (8 marks)

Question

Problem Context - Multi-Source Open-Source Information Gathering: A security team is authorized to footprint an organization that owns the domain examplecorp.example before a penetration test. Each engagement must gather information from WHOIS, DNS, search engines and public documents, organize it, and use it to understand the target's attack surface. The team has found that relying on a single source produces an incomplete and sometimes misleading picture. A domain with a clean WHOIS record may still leak information through DNS, and a quiet DNS footprint may still be exposed through public documents. The strategy must therefore combine several sources and judge their reliability rather than trusting one.

- Design a footprinting strategy that combines passive and active techniques (WHOIS, DNS records, search-engine operators and archived pages) and classify each technique as passive or active.
- Collect information from an authorized domain using appropriate tools such as whois, nslookup and dig, and organize the findings by source.
- Ensure that out-of-scope domains, personal data and unverified results are not treated the same as authorized, verified, in-scope findings.
- Construct four contrasting targets: a well-protected domain; a domain that leaks information; a domain with misconfigured DNS; and a domain with a minimal public footprint.
- For every target, predict what information will be found before collection and compare it with the actual result.
- Record the sources queried and the records found, and identify cases where one source contradicts another.
- Evaluate whether the chosen sources are reliable and whether any source produces misleading or outdated information.

Changed Condition: The scope grows from one domain to fifty subdomains and several third-party services. Evaluate the original strategy, modify it where necessary, and defend whether it remains suitable for large-scale authorized reconnaissance.

Evidence Expected: Footprinting strategy design, authorized test targets, collected-source records, prediction-versus-observation analysis, source-reliability analysis, scope analysis and a justified final strategy.

Answer

1.1 Strategy design - techniques classified passive / active

Technique	Tool / operator	Class	Why this class	Output
WHOIS lookup	whois examplecorp.example	Passive	Queries the registry/registrar, not the target	Registrar, dates, name servers, contact (often redacted)
Search-engine operators	site: filetype: intitle: inurl:	Passive	Uses the search index; no packet reaches the target	Subdomains, public documents, metadata
Archived pages	Wayback Machine snapshots	Passive	Reads a third-party copy	Old hosts, old documents, removed pages
Certificate / passive-DNS look-ups	CT logs, passive-DNS services	Passive	Third-party databases	Historical host names
DNS record queries	dig / nslookup (A, MX, NS, TXT)	Active (low)	Queries the target's authoritative servers, so it appears in their logs	Live records, mail and SPF policy
Zone-transfer attempt	dig axfr (only if RoE allows)	Active (intrusive)	Asks the server to disclose the entire zone	Full host list - only if misconfigured

1.2 Collection method (authorized domain, organised by source)

```
whois examplecorp.example
dig examplecorp.example NS +noall +answer
dig examplecorp.example A MX TXT +noall +answer
nslookup -type=MX examplecorp.example
site:examplecorp.example filetype:pdf
site:examplecorp.example -www intitle:"login"
web.archive.org/web/*/examplecorp.example/*    (archive listing)
```

Every result is written to a findings register with the columns: Finding ID | Target | Source | Query used | Raw result | Date/time | Tag (A/B/C/D below) | Verified by.

1.3 Separating verified, unverified, personal and out-of-scope data

Tag	Meaning	Handling
A - Verified, in-scope	Host/record confirmed by DNS and listed in the RoE asset list	Used in the attack-surface map
B - Unverified, in-scope	Seen only in search or archive, not confirmed by DNS	Kept as a lead; must be re-queried before use
C - Personal data	Names, e-mails, document metadata about people	Redacted, minimised, reported to the DPO; not used for targeting
D - Out-of-scope	Domain/service not in the authorization	Logged as 'seen', never queried, discarded from the map

1.4 Four contrasting lab targets - prediction versus observation

Target	Predicted items (W/D/S/A)	Observed items (W/D/S/A)	Pred. total	Obs. total	Verdict
T1 Well-protected	3 / 4 / 1 / 1	3 / 4 / 1 / 1	9	9	Matched

(secure.lab.example)					
T2 Leaky (leaky.lab.example)	3 / 5 / 6 / 2	3 / 5 / 9 / 2	16	19	Under-predicted by 3
T3 Misconfigured DNS (misconf.lab.example)	3 / 5 / 1 / 2	3 / 6 / 1 / 3	11	13	Under-predicted by 2
T4 Minimal footprint (minimal.lab.example)	2 / 2 / 0 / 0	2 / 2 / 0 / 0	4	4	Matched

W = WHOIS, D = DNS, S = search engines, A = archive. Items are counted as: WHOIS = registrar + each name server; DNS = each NS + each host record; search = each host + document + personal-data hit; archive = each historic host.

Why the predictions failed. T2 leaked three more search items than predicted (extra document hits carrying staff names), and T3 had an unexpected legacy name server and an old 'legacy-app' host in the archive. In both cases the single-source view (WHOIS or DNS) looked clean while another source disagreed, which is exactly the problem the scenario describes.

1.5 Contradictions between sources

Target	Contradictions found	Verified hosts (A)	Unverified leads (B)	Personal-data hits (C)
T1 Well-protected	None	2	0	0
T2 Leaky	search shows 'dev' not in DNS; search shows 'staging' not in DNS; archive shows 'old-portal' not in DNS	3	3	2
T3 Misconfigured DNS	WHOIS NS set != DNS NS set; archive shows 'legacy-app' not in DNS	4	1	0
T4 Minimal footprint	None	1	0	0

1.6 Source-reliability analysis

Source	Reliability (0-1)	Strength	Where it misleads
DNS (authoritative)	0.95	Live, authoritative data	Split-horizon hides internal names; resolver cache can return old answers
WHOIS	0.70	Ownership and registrar facts	Privacy redaction; name servers at registrar may differ from DNS (T3)
Search engines	0.60	Finds documents and forgotten hosts	Stale index, namesake organisations, duplicates
Archived pages	0.40	Shows history	Outdated - lists hosts that no longer exist (T2 old-portal, T3 legacy-app)

Conclusion: DNS is trusted for confirmation, WHOIS for ownership, while search and archive results are treated as leads (tag B) until DNS confirms them.

1.7 Changed condition - 50 subdomains and third-party services

Strategy	Queries for 1 domain	Queries for 50 subdomains
Original (per-domain loop: WHOIS, 4 DNS types, AXFR try, 4 search operators, 1 archive)	11	550
Modified (shared look-ups and batching)	-	132 (76% fewer)

Modifications: (1) WHOIS once for the apex domain, not per subdomain; (2) NS and zone-transfer check once per delegated zone; (3) A and TXT per host, MX only for mail hosts; (4) one site: query per apex plus one per third-party service; (5) certificate-transparency and passive-DNS look-ups to

discover subdomains instead of guessing; (6) a wildcard-DNS probe so wildcard answers are not counted as 50 real hosts; (7) third-party services (e.g. SaaS, cloud DNS) are recorded passively and are never queried actively unless the provider's permission is in the authorization.

Defence: the original strategy's principles (multi-source, tagging, source reliability) still hold at scale, but its per-domain loop does not - it would send 550 queries and repeat shared look-ups. The modified strategy keeps the same checks with 132 queries, so it remains suitable for large authorized reconnaissance. Remaining limitation: passive sources are rate-limited and may still lag behind newly created subdomains.

Q2 - Build a Reliable DNS Footprinting Workflow (7 marks)

Question

Problem Context - Conflicting and Misconfigured DNS Data: An authorized assessment must map a target's DNS by retrieving A, MX, NS and TXT records and, only where explicitly permitted, attempting a zone transfer. Records may be inconsistent, delegated to third parties, cached or misconfigured, so the workflow must interpret the results carefully rather than reporting them at face value.

- Develop a DNS footprinting workflow using dig and nslookup that retrieves A, MX, NS and TXT records, and attempts a zone transfer only where authorized.
- Evaluate how split-horizon DNS, delegation and caching change the information visible to an external tester.
- Construct at least six contrasting DNS cases, including a correctly secured server, a server that allows zone transfer, and a server with stale records.
- For each case, predict the records exposed, run the workflow, trace what each query returns, and compare the result with the prediction.
- Evaluate whether a misconfigured zone transfer meaningfully changes the attacker's knowledge and the resulting risk.
- Introduce a countermeasure such as restricting transfers or using TSIG, and redesign the analysis to show the reduced exposure.

Note: Evidence should include the DNS workflow, record analysis, authorized test cases, prediction-versus-observation comparisons, zone-transfer risk evaluation and the countermeasure redesign.
Evidence Expected: DNS workflow, record analysis, authorized test cases, prediction-versus-observation, zone-transfer risk evaluation and countermeasure redesign.

Answer

2.1 DNS footprinting workflow

1. Check the RoE: is the domain in scope, and is 'zone transfer' listed as permitted?

2. Find the name servers: dig example.lab NS +short.

3. For each record type (A, MX, NS, TXT) query the default resolver and cross-check with nslookup -type=<T>.

4. Query an authoritative server directly with no recursion: dig +norecurse @ns1.example.lab A www.example.lab - and compare with the cached answer.

5. Follow delegation (dig +trace); if a sub-zone is delegated to a third party outside the RoE, stop there and record it as out-of-scope.

6. Only if authorized: dig axfr example.lab @ns1.example.lab. Record 'refused' or the records returned.

7. Interpret: flag stale records, differences between views, and anything that differs from the prediction.

```
dig example.lab A MX NS TXT +noall +answer
nslookup -type=TXT example.lab
dig +norecurse @ns1.example.lab A www.example.lab
dig +trace sub.example.lab
dig axfr example.lab @ns1.example.lab    # only if RoE permits
```

2.2 How split-horizon, delegation and caching change what a tester sees

Condition	Effect on an external tester	Workflow response
Split-horizon DNS	Only the external view is returned; internal names are invisible, so a clean result does not mean a small network	Report 'external view only'; never claim a complete host list
Delegation	Parent zone returns only an NS referral; real records are on another party's servers	Stop at the referral if the delegate is out of scope
Caching	A recursive resolver may return an old answer until the TTL expires	Confirm with +norecurse against the authoritative server; use the authoritative value

2.3 Six contrasting cases - prediction versus observation

Case	Predicted A/MX/NS/TXT	Observed A/MX/NS/TXT	Queries	Zone transfer	Result
D1 Correctly secured	2 / 1 / 2 / 1	2 / 1 / 2 / 1	5	refused	Matched
D2 Zone transfer allowed	3 / 1 / 2 / 1	3 / 1 / 2 / 1	5	allowed	Matched
D3 Stale records	3 / 1 / 2 / 1	3 / 1 / 2 / 1	5	refused	Matched
D4 Split-horizon DNS	1 / 1 / 1 / 1	1 / 1 / 1 / 1	5	refused	Matched
D5 Delegated sub-zone (third party)	2 / 1 / 2 / 1	0 / 0 / 2 / 0	5	n/a (out of scope)	MISMATCH
D6 Cached / inconsistent answer	1 / 1 / 2 / 1	1 / 1 / 2 / 1	6	refused	Matched

2.4 Trace and interpretation of each case

Case	What the queries returned	Interpretation
D1 Correctly secured	AXFR refused (allow-transfer restricted)	Behaves as designed; nothing beyond published records.
D2 Zone transfer allowed	AXFR succeeds - full zone disclosed	Transfer succeeded: 12 host names disclosed instead of 3.
D3 Stale records	oldcrm points to decommissioned IP - record exists but is not a live asset	Counts matched, but oldcrm is a dead asset. The count alone would overstate the attack surface; validate against the asset inventory.
D4 Split-horizon DNS	External view hides 7 internal names	Counts matched the external view, but 7 internal names exist and cannot be seen from outside.
D5 Delegated sub-zone (third party)	Parent returns referral only; third-party DNS is out of scope - stop	Prediction was wrong: A, MX and TXT cannot be read from the parent; only the referral is visible. Workflow stopped correctly.
D6 Cached /	Recursive resolver (cached, TTL 300)	Resolver returned 203.0.113.5 (cached, TTL

inconsistent answer	differs from authoritative answer	300); authoritative server returned 203.0.113.9. Report the authoritative value.

2.5 Does a misconfigured zone transfer matter?

Yes. In case D2 the attacker's knowledge grows from **3 host names to 12**. Risk score (sensitive-looking names such as vpn, dev, hr-db, dc01, backup, admin, jenkins weigh 3, other names 1) rises from **5 to 32**. The names exposed (e.g. hr-db, dc01, jenkins) cannot be found by search engines or archives, so the transfer hands over a ready-made target list. It does not break into anything by itself, but it removes the guessing effort, so the finding is rated High for information disclosure.

2.6 Countermeasure and redesigned analysis

```
# BIND - restrict transfers to the secondary only
zone "example.lab" { type master; file "db.example.lab"; allow-transfer {
192.168.56.2; }; };

# BIND - or require a TSIG key
key "xfer-key" { algorithm hmac-sha256; secret "<base64>"; };
zone "example.lab" { ... allow-transfer { key "xfer-key"; }; };
```

D2 state	AXFR result	Host names exposed	Risk score
Before countermeasure	Allowed	12	32
After allow-transfer / TSIG	Refused	3	5

Exposure falls by **84.4%**. Redesigned workflow step: after the AXFR attempt, re-run it from an unauthorized address and without the TSIG key to prove that it is refused. Extra measures: monitor AXFR requests in server logs and keep internal names in a separate internal view.

Q3 - Create a Competitive-Intelligence Awareness Utility (7 marks)

Question

Problem Context - Public Information and Human-Risk Exposure: A department is building a repeatable workflow that collects public business information about an authorized organization from job advertisements, annual reports, press releases and public profiles, and assesses how that information could support social-engineering attacks such as phishing, vishing, pretexting and tailgating, so that awareness and countermeasures can be designed. No social-engineering attack is performed against real people.

- Design documented steps for each public source and record where each item came from, using search-engine operators such as site:, filetype: and intitle:.
- Map each collected item to the social-engineering technique it could enable (phishing, vishing, pretexting or tailgating) and the indicator a target should notice.
- Create test organizations containing rich, sparse and misleading public information.
- Predict the information and the human-risk level expected from each source before collection.
- Evaluate whether the collected information meaningfully increases social-engineering risk and which source is the most dangerous.
- Add two new sources or two new awareness countermeasures without restructuring the whole workflow, and evaluate the effect.
- Record the sources queried, the items found and the countermeasures recommended.

Inquiry: Design and implement a modular competitive-intelligence and awareness workflow using documented sources and operators, and evaluate the human attack surface of an authorized organization.

Evidence Expected: Workflow architecture, source operators, item-to-technique mapping, test organizations, prediction-versus-observation, risk evaluation and recommended countermeasures.

Answer

3.1 Workflow architecture (modular)

Source modules (one per source) -> Collector -> Item register -> Technique mapper -> Risk scorer -> Countermeasure recommender -> Awareness report. Each source is a self-contained module with the same interface (query list in, items out), so a new source or countermeasure is added as a new module or a new table row without changing the other stages.

3.2 Documented steps and operators per source

Source	Operators / steps	Recorded with each item
Job advertisements	site:careers.examplecorp.example ; intitle:"hiring" "ExampleCorp" ; note technologies, team sizes, locations	URL, date, quoted requirement
Annual reports	site:examplecorp.example filetype:pdf "annual report" ; note sites, headcount, acquisitions	URL, page number, date
Press releases	site:examplecorp.example inurl:press intitle:"announces" ; note partners, executives, projects	URL, date
Public profiles	Organisation page only: staff titles, e-mail format, photos of premises. No personal data is stored beyond role titles	Profile page, role

3.3 Item-to-technique mapping (rich organization)

Collected item	Technique enabled	Indicator the target should notice
Hiring ServiceNow admin; Okta SSO and Cisco VPN named	Phishing	Unexpected SSO / MFA prompt
Night-shift helpdesk team of four	Vishing	Caller urges a password reset or asks for a code
New HQ block C, 400 staff	Tailgating	Unbadged person following staff in
Acquisition of VendorX, systems merging	Pretexting	'Migration' request for credentials
New CFO and executive names	Phishing	Urgent payment e-mail from 'CEO/CFO'
Payments partner PayCo announced	Pretexting	Vendor bank-detail change request
Staff titles and first.last@ e-mail format	Phishing	Role-tailored spear-phish
Photo showing badge and entrance	Tailgating	Unfamiliar or cloned badge at the door

3.4 Test organizations

Organization	Public footprint	Items found (valid / total)
Rich	All four sources full of operational detail	8 / 8
Sparse	Only generic adverts, one press note, CEO name	3 / 3
Misleading	Outdated 2016 advert, fake staff profiles, unverified rumour, one real figure	1 / 4

3.5 Prediction versus observation (risk level per source)

Risk score = sum of item weights (1 low value ... 3 high value) for valid items. Levels: Low 0-2, Medium 3-5, High 6 or more.

Organization	Source	Valid score	Predicted	Observed	Result
Rich	job_ads	5	High	Medium	Differs
Rich	annual_report	5	Medium	Medium	Matched

Rich	press_release	5	Medium	Medium	Matched
Rich	public_profiles	6	High	High	Matched
Sparse	job_ads	1	Low	Low	Matched
Sparse	annual_report	0	Low	Low	Matched
Sparse	press_release	1	Low	Low	Matched
Sparse	public_profiles	2	Low	Low	Matched
Misleading	job_ads	0	Medium	Low	Differs
Misleading	annual_report	1	Low	Low	Matched
Misleading	press_release	0	Medium	Low	Differs
Misleading	public_profiles	0	High	Low	Differs

8 of 12 predictions matched. Job ads in the rich organization were over-predicted (score 5 = Medium, not High). The three misleading-organization cells were over-predicted because the items were outdated or fake and scored zero - although they still cost analyst effort (wasted items: 1 in job ads, 1 in profiles, 1 in press releases).

3.6 Does the information increase risk? Which source is most dangerous?

Source (rich organization)	Valid score	Risk level
job_ads	5	Medium
annual_report	5	Medium
press_release	5	Medium
public_profiles	6	High

Totals: rich = 21, sparse = 4, misleading = 1 (valid). Information therefore increases risk strongly only when it is rich **and** accurate. The most dangerous source is **public profiles** (score 6): the e-mail format and role titles allow tailored phishing, and a photo of a badge supports tailgating. By technique, phishing carries the most exposure (9), then pretexting (5), tailgating (5), vishing (2). Misleading data is not harmless - it can also mislead a defender's own risk assessment.

3.7 Extension without restructuring

Two new source modules were added to the register: **conference talks** (engineer talk reveals ticket workflow, pretexting, weight 2) and **vendor case studies** (names security tooling, phishing, weight 1). The rich total rises from 21 to **24**. Two new countermeasures were also added as rows: **call-back verification** (vishing, pretexting) and **badge / photo policy** (tailgating).

Countermeasure set	Residual risk (rich org, with new sources)
Existing: phishing awareness training only (-40% phishing)	20
Existing + call-back verification + badge policy (-50% each on their techniques)	13

The two new countermeasures cut residual risk by about 35%. (Mitigation percentages are modelling assumptions to be justified in your viva.)

3.8 Recommended countermeasures

Technique	Countermeasure
Phishing	Report-phish button, check sender and URL, MFA number-matching, restrict public e-mail format
Vishing	Call-back to a known number; never read out codes; helpdesk identity script

Pretexting	Out-of-band approval for vendor changes and 'migration' requests; limit tech detail in job ads
Tailgating	Badge-check culture, visitor escort, no photos of badges or entrances online

Sources queried: 4 base + 2 added. Items found: rich 8 (+2 new), sparse 3, misleading 4 (1 valid).

Q4 - Design a Reconnaissance Data-Validation Mechanism (6 marks)

Question

Problem Context - High-Stakes Reconnaissance Data Quality: A reconnaissance data-collection process receives results that may be incomplete, outdated, duplicated or out of scope. Acting on poor-quality data wastes effort and can breach the agreed scope, so each item must be validated before it is used.

- Develop a validation mechanism that checks each collected item for scope, freshness, duplication and source reliability.
- Distinguish a recoverable item (one that needs a re-query or confirmation) from an item that must be rejected (out of scope or unverifiable).
- Construct at least five test sequences, including all-valid, out-of-scope, stale and duplicated data.
- Predict how many items pass, fail or need re-checking before running the validation.
- Evaluate whether the order of the validation checks affects effort and accuracy.
- Redesign the validation order to reduce unnecessary checks while still keeping out-of-scope data out.

Scalability Inquiry: Predict and analyse the validation outcomes and the effort required as the volume of collected data grows from one target to fifty targets.
Evidence Expected: Validation design, adversarial reconnaissance sequences, pass/fail/re-check analysis, ordering evaluation and a justified redesign.

Answer

4.1 Validation design

Check	Rule	Cost units
Scope	Item's target is in the RoE asset list	1
Freshness	Item age is 90 days or less	1
Duplication	Item key not already seen (hash look-up)	2
Source reliability	Source rated 0.5 or higher, or the item is cross-confirmed (needs a confirming query)	3

Decision	Triggered by	Class	Action
REJECT	Out of scope; or unverifiable (unreliable source)	Not recoverable	Discard and log
DUPLICATE	Same key already accepted	Not recoverable	Merge, no re-query
RECHECK	Stale only	Recoverable	Re-query / confirm, then re-validate
PASS	All checks passed	-	Use in the attack-surface map

```
for item in items:
    for check in ORDER:                 # e.g. scope, rel, dup, fresh
        if fails(check, item): decision = CLASS[check]; break    # short-circuit
    else: decision = PASS
```

```
    seen.add(item.key)
```

4.2 Five test sequences - predicted versus observed outcomes

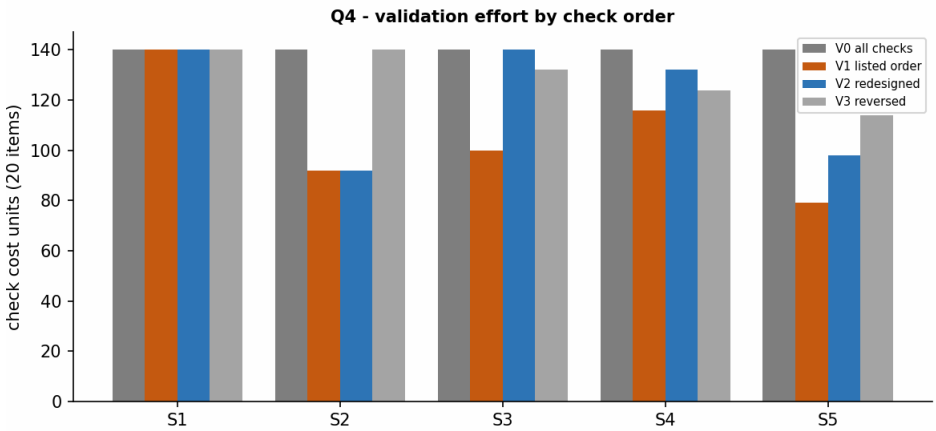
Prediction = counting each flaw separately before running (a naive prediction). Observed = result of the final (redesigned) mechanism. Format: Pass / Recheck / Reject / Duplicate.

Sequence	Items	Predicted	Observed	Match
S1 all-valid	20	20 / 0 / 0 / 0	20 / 0 / 0 / 0	Yes
S2 out-of-scope	20	12 / 0 / 8 / 0	12 / 0 / 8 / 0	Yes
S3 stale	20	12 / 8 / 0 / 0	12 / 8 / 0 / 0	Yes
S4 duplicated	20	12 / 0 / 0 / 8	12 / 0 / 0 / 8	Yes
S5 mixed adversarial	20	6 / 6 / 8 / 3	6 / 3 / 8 / 3	No

S1-S4 matched. In S5 the naive prediction double-counted items that have two flaws: it predicted 6 re-checks but only 3 are real, because three stale items are also out of scope, unreliable or duplicates (so they are rejected or merged instead). This is the main prediction lesson: flaws overlap, and the priority rule (reject > duplicate > recheck) decides the outcome.

4.3 Does the order of checks matter?

Order (short-circuit unless stated)	S5 cost	S5 accuracy	Wasted re-checks	Out-of-scope items sent to re-check
V0 all checks	140	20/20	0	0
V1 listed order (scope,fresh,dup,rel)	79	18/20	2	0
V2 redesigned (scope,rel,dup,fresh)	98	20/20	0	0
V3 reversed (rel,dup,fresh,scope)	114	19/20	1	1



Yes. The cheapest order (V1, as listed in the task) is only 90% accurate: it checks freshness before reliability and duplication, so a stale item that is actually unreliable or duplicated is wrongly sent for re-checking (2 wasted re-checks). The reversed order (V3) is worse for safety: one stale + out-of-scope item was sent for re-checking, which would mean re-querying an out-of-scope target - a scope breach. Running all checks (V0) is accurate but wastes effort.

4.4 Justified redesign

Order: Scope -> Reliability -> Duplication -> Freshness (V2). Reasoning: (1) scope first, because it is the cheapest check and the only one that can cause a scope breach - nothing out of scope is ever re-queried; (2) reliability second, so unverifiable items are rejected before any re-query is planned; (3) duplication third, so duplicates are merged rather than re-checked; (4) freshness last, so only items

that are otherwise valid get a re-check. V2 reaches 100% accuracy with no wasted re-checks and no scope breach, at 30% lower effort than running all checks (98 vs 140 units on S5).

4.5 Scalability: 1 to 50 targets (S5 pattern per target)

Targets	Items	Cost V0 (all checks)	Cost V1 (listed)	Cost V2 (redesigned)	V1 accuracy	V1 wasted re-checks
1	20	140	79	98	90%	2
10	200	1400	790	980	90%	20
50	1000	7000	3950	4900	90%	100

Prediction: effort and outcomes grow linearly (about 7 units per item for V0, 4.9 for V2) because the duplicate check uses a hash look-up. Observation confirmed it: 20 -> 1000 items, V2 cost 98 -> 4,900, and the wasted re-checks of V1 grow from 2 to 100. Poor ordering therefore scales into hundreds of pointless re-queries.

Q5 - Evaluate Footprinting of a Hierarchical Organization (7 marks)

Question

Problem Context - Irregular Multi-Level Organizational Footprint: A target organization has a nested public footprint of a parent domain, subdomains, departments and third-party services. Footprinting must traverse this hierarchy level by level, recording each level and stopping cleanly at out-of-scope or terminal nodes.

- Represent the organization's public footprint as a hierarchy (domain, subdomains and services) that can be traversed systematically.
- Develop a systematic traversal that records each level and stops at out-of-scope or terminal nodes using an explicit boundary condition.
- Construct shallow, deeply nested and irregular footprints with branches of differing size.
- Predict the number of nodes and the information expected before the traversal.
- Evaluate how depth and branching affect the effort and completeness of the footprinting.
- Include an empty branch or a node with no public data and evaluate whether the boundary condition handles it correctly.
- Compare the systematic traversal conceptually with an ad-hoc, unstructured approach.

Test Your Design: Verify whether the traversal correctly covers shallow, deep and irregular footprints without leaving the authorized scope.

Correctness Inquiry: Predict and verify the expected coverage, the boundary handling and the number of nodes visited.

Evidence Expected: Hierarchical footprint representation, traversal design, test structures, prediction-versus-observation, boundary analysis and a justified final design.

Answer

5.1 Hierarchical representation

The footprint is a tree. Each node = {name, scope (IN/OUT, from the RoE), data (number of public items), children}. Levels: L0 parent domain -> L1 subdomains / departments / third-party services -> L2+ sub-services.

5.2 Traversal with explicit boundary condition

Boundary condition: visit a node only if node.scope = IN **and** its parent was visited **and** depth is 8 or less. An out-of-scope node is recorded as a 'stop' but is not queried and its whole subtree is skipped (scope is inherited, so an in-scope-looking child of an out-of-scope parent is not entered). A node

with no children is terminal. A node with data = 0 is **empty**: it is recorded as empty but traversal still continues to its children.

```
level = [root]; depth = 0
while level and depth <= MAX_DEPTH:
    next = []
    for node in level:
        if node.scope != IN: stops += 1; continue        # boundary - do not query, do
not descend
        record(node, depth)                               # query A, NS, TXT
        next += node.children                             # empty list = terminal
    level = next; depth += 1
```

5.3 Test structures and prediction versus observation

Structure	Total nodes	Predicted nodes / items / stops	Observed nodes / items / stops	Depth	Max branching	Result
Shallow	5	5 / 10 / 0	5 / 10 / 0	2	4	Matched
Deep	6	5 / 4 / 0	6 / 5 / 0	6	1	Prediction corrected
Irregular	17	13 / 16 / 2	13 / 16 / 2	4	6	Matched

Shallow and irregular predictions (made by hand from the diagrams) matched. For the deep chain I predicted 5 nodes and 4 items; the traversal found 6 nodes and 5 items (root + a, b, c, d, e) - a counting error in my prediction, not a traversal fault. Level-by-level output for the irregular footprint: L0 [corp.example]; L1 [www, dev, support, legacy]; L2 [api, ci, kb, tickets, old]; L3 [v1, v2, v3]. The two out-of-scope branches (hr and shop, with their children payroll and pay) were stopped at L1, giving 2 stops and no queries.

5.4 Effect of depth and branching on effort and completeness

Structure	Depth (levels)	Max branching	Nodes visited	Queries (3 per node)	Coverage of in-scope nodes
Shallow	2	4	5	15	100%
Deep	6	1	6	18	100%
Irregular	4	6	13	39	100%

Effort grows with the number of nodes, not depth alone: the irregular tree (13 nodes, branching 6) costs 39 queries while the deep chain (6 nodes) costs 18. Depth costs time because a level cannot start until the previous one is finished; branching costs queries. Completeness stays 100% because the traversal is exhaustive and only the boundary can stop it.

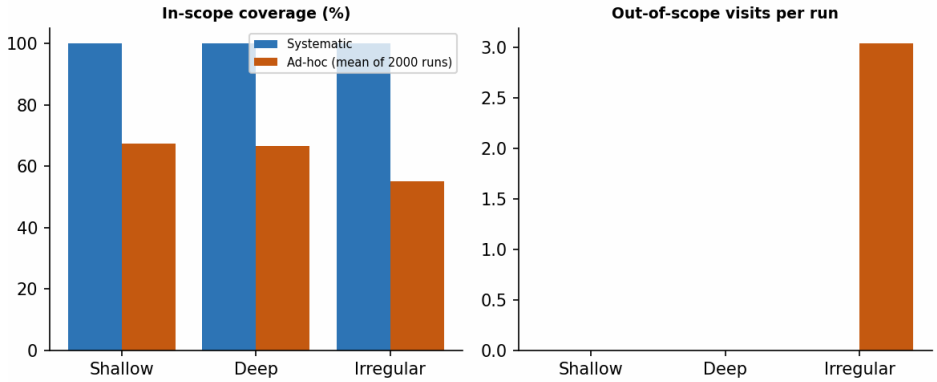
5.5 Empty branches and the boundary condition

Empty nodes occurred in all test trees (ci, kb, legacy in the irregular tree; e in the deep chain). They did not stop the traversal wrongly: leaf nodes ci, kb and e ended cleanly as terminal nodes, and 'legacy' (empty, but with a child) still led to 'old', which holds 1 item. This shows the boundary depends on scope and the absence of children, not on whether data was found.

5.6 Systematic traversal versus an ad-hoc approach

Structure	Systematic coverage	Ad-hoc coverage	Systematic out-of-scope visits	Ad-hoc out-of-scope visits per run	Ad-hoc repeated visits per run
Shallow	100%	67.4%	0	0	1.63
Deep	100%	66.6%	0	0	2

Irregular	100%	55%	0	3.04	3.67



Ad-hoc is modelled as picking nodes at random (with repeats) with the same query budget. It misses 33-45% of in-scope nodes, repeats work, and on the irregular footprint visits about 3 out-of-scope nodes per run - a scope breach. The systematic traversal costs the same number of queries, covers every in-scope node once, and never leaves scope. **Final design:** BFS with the explicit boundary condition above.

Q6 - Evaluate Footprinting Approaches Under Constraints (7 marks)

Question

Problem Context - Reconnaissance Under Time and Stealth Constraints: An authorized assessment must gather enough information while balancing speed, completeness and the risk of detection. Passive open-source collection and more active footprinting have different trade-offs, so the better approach depends on the scope and the constraints.

- Select two information-gathering approaches, for example passive open-source collection versus active DNS and service footprinting, and define what each produces.
- Apply both approaches to the same authorized target.
- Test at least four increasing scope sizes, including one at which one approach becomes impractical.
- Record the number of queries or steps and the time taken where useful.
- Evaluate redundant or repeated collection in each approach and identify where effort is wasted.
- Determine whether the faster or the quieter approach is always the better engineering choice.
- Defend a recommendation for a small-scope engagement and for a large-scope engagement.

Inquiry: The workflow is used both for teaching and for repeated real assessments; justify the chosen approach for each context.

Evidence Expected: Approach definitions, two workflows, quantitative measures, redundancy analysis and a defended recommendation.

Answer

6.1 Approach definitions

Approach	Techniques	Produces	Visible to target?
A - Passive open-source	WHOIS, search operators, archive, CT logs, document review	Ownership, public hosts, documents, history (about 55% of what exists - model value)	No
B - Active DNS and service	dig / nslookup (NS, A, MX, TXT),	Live records and services (about	Yes - every

footprinting	authorized AXFR attempt, 4 service-port checks per host	90% - model value)	query can appear in logs

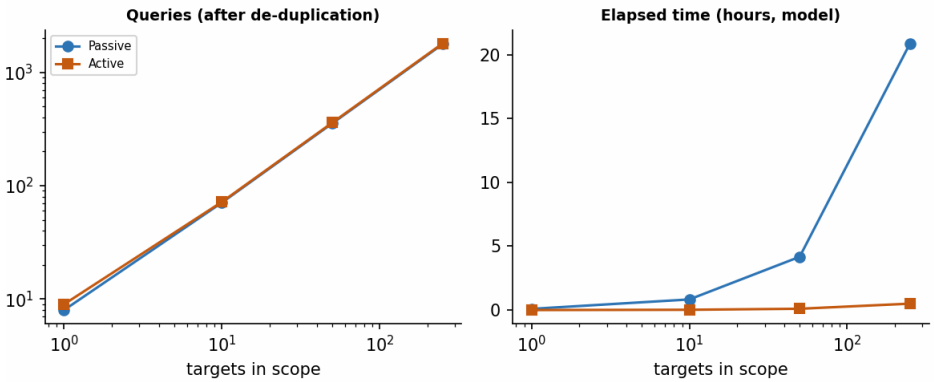
6.2 The two workflows (same authorized target)

A (passive): WHOIS (1) -> 5 search-operator queries -> 1 archive query -> 1 certificate-transparency query = 8 queries per target, then about 45 s of analyst reading per target. **B (active):** NS, A, MX, TXT, AXFR check (5 DNS queries) -> 4 service checks = 9 queries per target, all visible to the target.

6.3 Four scope sizes - quantitative measures

Model assumptions (replace with your own measurements if you run the lab): passive 3 s per query but search engines throttle to about 100 queries/hour; active 0.5 s per query but throttled to 60 queries/minute to stay under an assumed IDS alert threshold; WHOIS shared by one apex per 10 targets; NS and AXFR shared per zone of 10 targets.

Targets	A: queries (naive -> de-duplicated)	A: time (h)	A: target-visible	B: queries (naive -> de-duplicated)	B: time (h)	B: target-visible
1	8 -> 8	0.09	0	9 -> 9	0	9
10	80 -> 71	0.83	0	90 -> 72	0.02	72
50	400 -> 355	4.17	0	450 -> 360	0.1	360
250	2000 -> 1775	20.88	0	2250 -> 1800	0.5	1800



At 250 targets the passive approach needs about 20.88 hours, almost all of it waiting for search-engine rate limits and manual reading, so it becomes **impractical for large scope**. The active approach finishes in about 0.5 hours but sends 1800 visible queries, so it is **noisy and may trigger detection**.

6.4 Redundancy analysis

Passive: repeated WHOIS for hosts under the same apex - at 250 targets, 2,000 naive queries fall to 1,775 (225 saved) after sharing WHOIS. Repeated search queries about the same apex are another waste. Active: NS and AXFR checks repeated for every host in the same zone - 2,250 naive queries fall to 1,800 (450 saved). Both approaches waste effort by treating subdomains as independent when they share registration or zone.

6.5 Is the faster or the quieter approach always better?

No. Passive is the quietest but slowest at scale and finds only about 55% of what exists; active is faster and more complete but visible and, for zone transfers, intrusive. A fast scan that alerts the client's SOC may breach the agreed test conditions, and a quiet but incomplete one gives false confidence. The right choice depends on scope size, the detection constraint in the RoE and the required completeness.

6.6 Recommendations

Context	Recommended approach	Defence
Small scope (1-10 targets)	Passive first, then targeted active DNS on confirmed hosts (hybrid)	Only 8-80 passive queries, so rate limits do not matter; the active step is small (a few dozen queries) and confirms leads; best completeness
Large scope (50-250 targets)	Passive for discovery with de-duplication; active DNS only on in-scope hosts, throttled and agreed with the client's SOC	Passive alone would take about 21 hours at 250 targets; active everywhere gives 1,800 visible queries. A hybrid halves visible queries (about 900) while keeping coverage near active level
Teaching	Manual passive + small active exercise	Learners see each source and its limits; low risk of unintended impact
Repeated real assessments	Scripted hybrid with de-duplication and logging	Repeatability, evidence and scope control matter more than seeing every step

Q7 - Integrated Review: Diagnose, Redesign and Defend (8 marks)

Question

- Select one workflow from Q1-Q6 that demonstrates a meaningful limitation, such as incomplete coverage, an unreliable source, excessive queries, weak validation or a risk of leaving scope, and improve it using evidence.

A. Diagnose the Limitation (2 marks): Identify the reconnaissance or logical bottleneck using evidence. Determine whether the limitation is caused by source unreliability, redundant collection, poor ordering or a risk of going out of scope.

B. Establish Evaluation Criteria (1 mark): Define measurable criteria against which the original workflow will be judged. Examples include coverage, the number of queries, source reliability, scope compliance and time.

C. Propose and Implement a Redesign (2 marks): Modify the original workflow to address the diagnosed limitation. Provide the design logic or the ordered steps before implementation. Identify any trade-off introduced by the redesign.

D. Validate and Compare (2 marks): Use equivalent test conditions for the original and the redesigned workflow. Collect quantitative evidence and determine whether the redesign actually improves the selected criterion.

E. Defend the Final Engineering Judgment (1 mark): Evaluate whether the redesign met its objective. Explain cases in which the original workflow may still be preferable. Defend the final choice using experimental evidence rather than subjective statements.

Evidence Expected: Diagnosis with evidence and cause; measurable criteria; redesigned workflow with design logic and trade-offs; quantitative comparison under equivalent conditions; justified final judgment including when the original is still preferable.

Answer

Selected workflow: the Q4 validation mechanism in its original form, V1 - checks run in the order listed in the task (scope, freshness, duplication, reliability) with short-circuiting.

A. Diagnosis (2 marks)

Evidence (S5 mixed adversarial, 20 items)	Correct (V0 truth)	Original V1
Re-check	3	5
Reject	8	7

Duplicate	3	2
Accuracy	20 / 20	18 / 20

Bottleneck: the original sends 5 items for re-checking, but only 3 deserve it. Two stale items were also unreliable or duplicated, so they should have been rejected or merged; re-querying them is wasted effort. At 50 targets this becomes **100 wasted re-checks (accuracy 90%)**.

Cause: poor ordering. It is not source unreliability (the reliability ratings are correct) and not redundant collection; the freshness check runs before reliability and duplication, so a recoverable label is given before stronger rejection reasons are examined. A related risk is shown by the reversed order V3, where a stale + out-of-scope item was sent to re-check - ordering can put scope at risk.

B. Evaluation criteria (1 mark)

Criterion	Measure	Target
Scope compliance	Out-of-scope items sent for re-query	0
Decision accuracy	Items classified same as full evaluation (V0)	100%
Wasted re-checks	Items re-queried that should be rejected or merged	0
Effort	Check cost units per 20 items	No more than 75% of V0 (105 units)
Source reliability	Items evaluated against a rated source	100%

C. Redesign (2 marks)

Design logic: apply checks in order of severity and cost - checks that can reject an item first, the check that only creates work (freshness) last.

1. Scope: out of RoE -> REJECT (cost 1; protects scope).
2. Source reliability: unverifiable -> REJECT (cost 3).
3. Duplication: already seen -> merge as DUPLICATE (cost 2).
4. Freshness: older than 90 days -> RECHECK (cost 1); this is the only route to a re-query.
5. Otherwise PASS.

Trade-off: the redesign spends the expensive reliability check on items that are only stale, so it costs more than the original on stale-heavy data (S3: 140 vs 100 units). It pays for correctness with some extra effort.

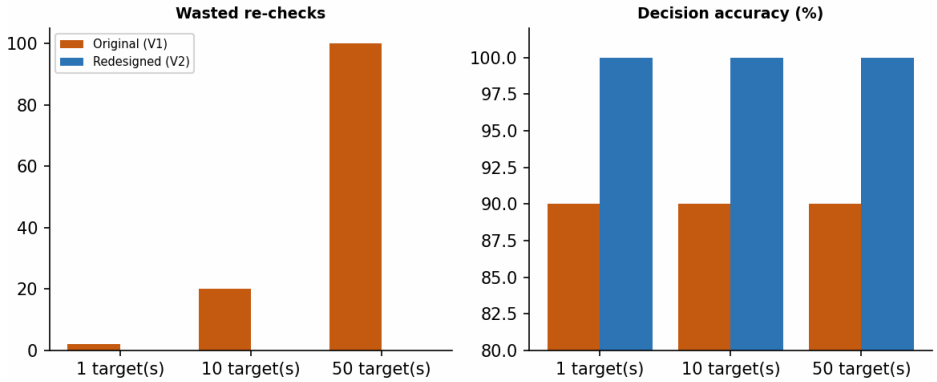
D. Validation and comparison (2 marks)

Equivalent conditions: identical sequences S1-S5, same item order, same cost model, same ground truth.

Sequence	Original V1 cost	Redesigned V2 cost	V1 accuracy	V2 accuracy	V1 wasted re-checks	V2 wasted re-checks
S1 all-valid	140	140	20/20	20/20	0	0
S2 out-of-scope	92	92	20/20	20/20	0	0
S3 stale	100	140	20/20	20/20	0	0
S4 duplicated	116	132	20/20	20/20	0	0
S5 mixed adversarial	79	98	18/20	20/20	2	0

Scale	Original V1 cost	Redesigned V2 cost	V1 accuracy	V2 accuracy	V1 wasted	V2 wasted
1 target(s)	79	98	90%	100%	2	0

10 target(s)	790	980	90%	100%	20	0
50 target(s)	3950	4900	90%	100%	100	0



The redesign improves the selected criteria: accuracy 90% -> 100%, wasted re-checks 100 -> 0 at 50 targets, scope breaches 0 throughout. Effort is 70% of V0 (4,900 vs 7,000 units at 50 targets), inside the 75% target, but 24% above the original V1 (3,950).

E. Final engineering judgment (1 mark)

Objective met: all four primary criteria are satisfied by V2 (scope breaches 0, accuracy 100%, wasted re-checks 0, effort 70% of V0), based on the measured results above rather than opinion.

When the original may still be preferable: where data are known to contain stale items but rarely overlap with unreliable or duplicated items (S1-S4 - there V1 is equally accurate: 20/20 - and cheaper, e.g. S3 at 100 vs 140 units), or when the reliability check is much more expensive than assumed. In mixed or adversarial data (S5) the original makes errors that waste re-queries. **Decision:** use V2 as the default, because wrong re-queries cost more than extra checks in an authorized engagement, and V1 only for pre-cleaned, stale-only batches.

Limitations: results come from synthetic sequences and an assumed cost model; confirm with the cost figures from your own lab runs.